

1 Cookie with Insecure or Improper or Missing SameSite attribute

```
services.Configure<CookiePolicyOptions>(options =>
{
    options.MinimumSameSitePolicy = SameSiteMode.Strict;
    options.HttpOnly = HttpOnlyPolicy.Always;
    options.Secure = CookieSecurePolicy.Always;

});
```

2 Missing HttpOnly Attribute in Session Cookie

```
services.AddSession(options =>
{
    options.Cookie.HttpOnly = true;

});
```

3 Missing Secure Attribute in Encrypted Session (SSL) Cookie

```
services.AddSession(options =>
{
    options.Cookie.SecurePolicy = CookieSecurePolicy.Always;

});
```

4 Missing or Insecure "Object-Src" or "Default-src" policy in "Content-Security-Policy" header and Missing or Insecure "Style-Src" or "Default-src" policy in "Content-Security-Policy"

```
app.Use(async (context, next) =>
{
    context.Response.Headers.Add("Content-Security-Policy",
"default-src 'self';font-src 'self' https://fonts.gstatic.com https://fonts.googleapis.com
```

```
https://stackpath.bootstrapcdn.com; script-src 'self' 'unsafe-inline' 'unsafe-eval'; style-src 'self'
https://stackpath.bootstrapcdn.com 'unsafe-inline'; img-src 'self' https://localhost:44323 data;;
connect-src 'self'; frame-src 'self'; object-src 'none'; media-src 'self'");
```

```
        await next();
    });
```

5 Permanent Cookie Contains Sensitive Session Information

```
services.Configure<CookiePolicyOptions>(options =>
{
    options.MinimumSameSitePolicy = Microsoft.AspNetCore.Http.SameSiteMode.None;
    options.HttpOnly = HttpOnlyPolicy.Always;
    options.Secure = CookieSecurePolicy.Always;
});
```

6 Session Identifier Not Updated

```
services.AddSession(options =>
{
    options.IdleTimeout = TimeSpan.FromMinutes(30); // Set an appropriate idle timeout
    options.Cookie.IsEssential = true; // Mark the session cookie as essential
    options.Cookie.SameSite = SameSiteMode.Strict; // Set SameSite attribute as needed
    options.Cookie.SecurePolicy = CookieSecurePolicy.Always; // Set Secure attribute as needed
    options.Cookie.HttpOnly = true; // Set HttpOnly attribute as needed
    // Enable session regeneration
    options.RegenerateSessionId = true;
});
```

7 Check for SRI (Subresource Integrity) support in ComplaintList Removed Online JS Files

```
URL: https://mrplhiq.businessstowork.com/applicant/ComplaintList
<script src="https://code.jquery.com/jquery-3.5.1.min.js" integrity="sha256-
9/aliU8dGd2tb6OSsuzixeV4y/faTqgFtohetphbbj0=" crossorigin="anonymous"></script>

<script
src="https://cdn.datatables.net/1.10.23/js/jquery.dataTables.min.js"></script>
```

8 Cross-Site Request Forgery 28

```
services.AddSession(options =>
{
options.Cookie.SameSite = Microsoft.AspNetCore.Http.SameSiteMode.Strict;
});
```

9 H Integer Overflow 8

Handle Overflow Exception for Integers